

漏洞报告 VULN-03: XSS跨站脚本

漏洞类型: XSS跨站脚本

测试小组: 天亮了吗

被测小组: 天亮了吗

测试时间: 2026-08-22

测试环境: 本机 localhost / 127.0.0.1:5001

测试账号: 课程测试账号, 未使用真实个人密码

1. 基本信息

本报告针对阶段二任务3, 仅在授权的本机课程靶场中完成。

2. 漏洞位置

URL/接口: 文件列表文件名、用户名模板变量、错误页面

请求方法: GET/POST/DELETE (按接口实际方法)

关键参数: username、password、filename、file、csrf_token (按任务适用)

所属功能: 文件列表/认证页面

3. 正常请求

先使用正常账号和合法参数完成对应功能, 再仅修改一个测试参数。请求记录和页面证据见附件目录。

正常请求示例: 在本机浏览器访问对应页面, 提交课程测试账号或合法文件; 不包含真实密码、Cookie 或 Token。

4. 漏洞复现步骤

1. 启动本机网盘并登录课程测试账号。
2. 按任务说明构造单一无害测试参数。
3. 发送请求并记录状态码、页面、文件或会话变化。
4. 使用修复后的同一参数再次验证。

5. 攻击效果或异常现象

使用脚本字符串作为文件名进行无害探测, 未反射脚本; 模板输出由 Jinja 自动转义。

6. 漏洞原因分析

未发现 |safe 或脚本上下文拼接, 用户输出经过 render_template。

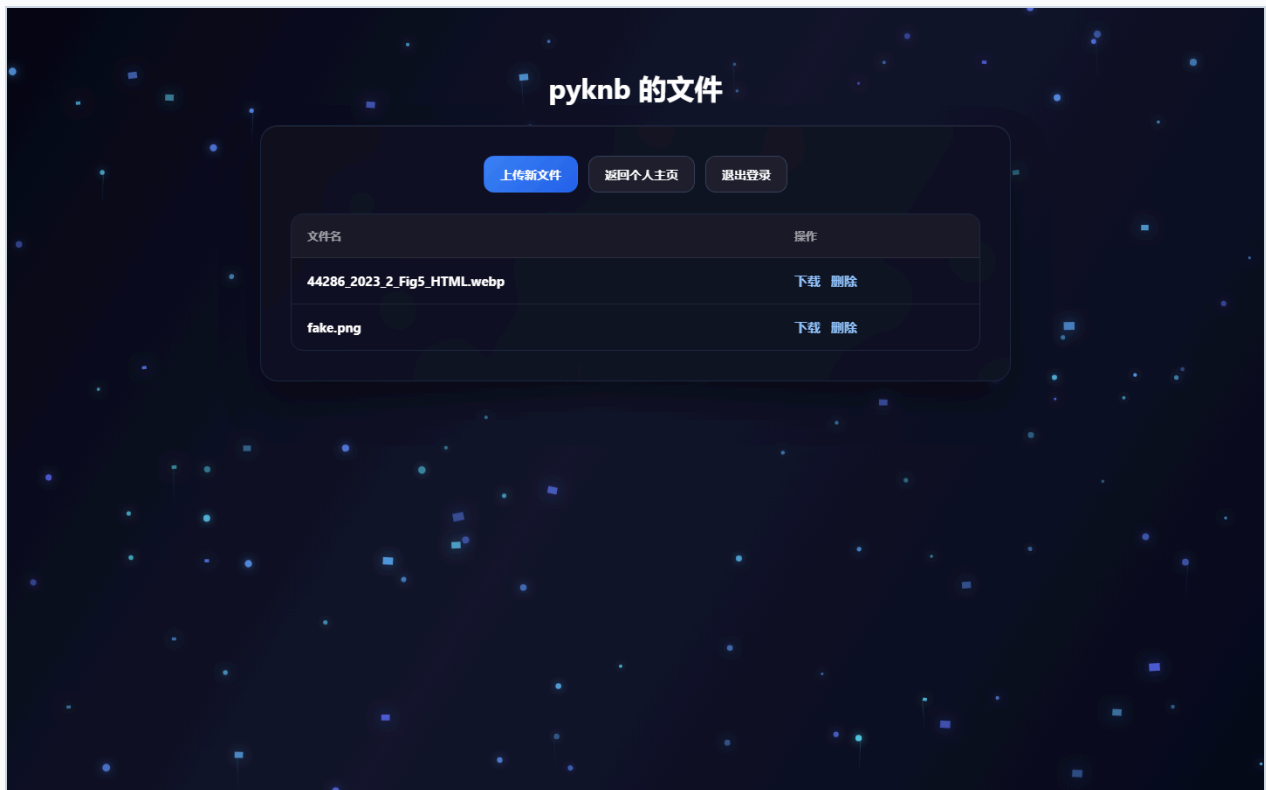
7. 影响范围

影响范围限于本机课程靶场及测试账号；不得外推为公网系统影响。具体后果取决于接口是否需要登录及资源归属。

8. 修复建议

保持自动 HTML 转义；禁止对用户输入使用 |safe；链接参数使用 urlencode 并限制输入长度。

9. 附件清单



pyknb 的文件

[上传新文件](#)[返回个人主页](#)[退出登录](#)

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

[← 返回网页](#)

登录

[登录](#)

[← 返回网页](#)

注册

用户名

密码

确认密码

注册

任务 03 修复代码证据

templates/filelist.html:145-165

```
145     <div class="table-wrap">
146         <table>
147             <thead>
148                 <tr>
149                     <th>文件名</th>
150                     <th>操作</th>
151                 </tr>
152             </thead>
153             <tbody>
154                 {% for file in files %}
155                 <tr>
156                     <td class="file-name">{{ file }}</td>
157                     <td>
158                         <div class="row-actions">
159                             <a href="/download?filename={{ file }}">下载</a>
160                             <a href="/delete?filename={{ file|urlencode }}&csrf_token={{ csrf_token() }}" onclick="return confirm('确定要
删除吗?')">删除</a>
161                         </div>
162                     </td>
163                 </tr>
164                 {% else %}
165                 <tr>
```

templates/login.html:1-25

```
1  <!DOCTYPE html>
2  <html lang="zh-CN">
3  <head>
4      <meta charset="UTF-8">
5      <title>登录--纯大子的网盘</title>
6      <link rel="stylesheet" href="{{ url_for('static', filename='login.css') }}">
7  </head>
8  <body>
9      <canvas class="particle-canvas"></canvas>
10     <a class="back-link" href="{{ url_for('index') }}">&larr; 返回网页</a>
11     <h2>登录</h2>
12     <form method="post" action="/login">
13         <input type="hidden" name="csrf_token" value="{{ csrf_token() }}">
14         <p class="error_message">{{ error or '' }}</p>
15         <!-- post方法提交数据和数据提交到当前网站的login路径-->
16         <input type="text" name="username" placeholder="用户名" value="{{ username or '' }}" autocomplete="username" required>
17         <input type="password" name="password" placeholder="密码" autocomplete="current-password" required>
18
19
20
21         <button type="submit">登录</button>
22     </form>
23     <script src="{{ url_for('static', filename='particle.js') }}"></script>
24 </body>
25 </html>
```